

Credit Card Fraud Detection API

This document describes how to call each route of the Credit Card Fraud Detection App

Base behavior (applies to all routes)

- **Admin guard (required):** every non-OPTIONS request must include:
 - **Header:** x-admin-secret: <EDGE_ADMIN_SECRET>
 - If missing/incorrect: **403** {"error":"Forbidden"}
- **Content-Type:** for JSON bodies, send Content-Type: application/json.

Routes

POST /signup

Create a new Supabase Auth user (admin user creation via service role key).

- **Method:** POST
- **Path:** /signup
- **Headers**
 - x-admin-secret (required)
 - Content-Type: application/json
- **Body**
 - email (string, required)
 - password (string, required)
 - name (string, optional; must be non-empty if provided)
- **Success**
 - **201** {"user": <supabase-admin-user-json>}
- **Errors**
 - **400** {"error":"Invalid or empty JSON"} (bad JSON)
 - **400** {"error":"Missing email or password"}
 - **400** {"error":"If provided, name must be a non-empty string"}
 - **4xx/5xx** {"error": ...} (propagated from Supabase Admin API)

Example:

```
curl -X POST "<BASE_URL>/signup" \  
-H "x-admin-secret: $EDGE_ADMIN_SECRET" \  
-H "Content-Type: application/json" \  
-d '{"email":"user@example.com","password":"Passw0rd!","name":"Jane"}'
```

GET /login

Log in using email/password by calling Supabase Auth REST token endpoint (password grant).

- **Method:** GET
- **Path:** /login?email=<email>&password=<password>
- **Headers**
 - x-admin-secret (required)
- **Query params**
 - email (required)
 - password (required)
- **Success**
 - **200**
 - {"user": <user|null>, "session": <token-response-json>}
- **Errors**
 - **400** {"error": "Missing email or password"}
 - **4xx/5xx** {"error": ...} (propagated from Supabase Auth REST API)

Example:

```
curl "<BASE_URL>/login?email=user@example.com&password=Passw0rd%21" \  
-H "x-admin-secret: $EDGE_ADMIN_SECRET"
```

POST /pns

Register/store a push notification device token (in table public.pns).

- **Method:** POST

- **Path:** /pns
- **Headers**
 - x-admin-secret (required)
 - Content-Type: application/json
- **Body**
 - user_id (string, required)
 - token (string, required)
 - platform (string, optional)
 - device_info (string, optional)
- **Success**
 - **201** {"pns": { "id", "user_id", "token", "platform", "device_info", "is_active", "created_at", "last_used_at" }}
- **Errors**
 - **400** {"error": "Invalid or empty JSON"}
 - **400** {"error": "Missing required fields: user_id, token"}
 - **400** {"error": "<db error message>"}

Example:

```
curl -X POST "<BASE_URL>/pns" \
-H "x-admin-secret: $EDGE_ADMIN_SECRET" \
-H "Content-Type: application/json" \
-d '{"user_id": "<uuid>", "token": "<pushy-device-token>", "platform": "ios"}
```

POST /notify

Send a push notification to all active device tokens for a given user (via Pushy).

- **Method:** POST
- **Path:** /notify
- **Headers**
 - x-admin-secret (required)
 - Content-Type: application/json

- **Body**
 - user_id (string, required)
 - text (string, required)
- **Success**
 - **200** {"pushy": <pushy-api-response>}
- **Errors**
 - **400** {"error": "Invalid or empty JSON"}
 - **400** {"error": "Missing required fields: user_id, text"}
 - **404** {"error": "No active device tokens for user"}
 - **500** {"error": "Server misconfig: missing PUSHY_SECRET_KEY"}
 - **4xx/5xx** {"error": ...} (from Pushy)

Example:

```
curl -X POST "<BASE_URL>/notify" \
-H "x-admin-secret: $EDGE_ADMIN_SECRET" \
-H "Content-Type: application/json" \
-d '{"user_id": "<uuid>", "text": "Fraud alert: suspicious transaction detected."}'
```

GET /dailyreport

Return fraud-flagged transactions between two timestamps (inclusive).

- **Method:** GET
- **Path:** /dailyreport?startTime=<ISO>&endTime=<ISO>
- **Headers**
 - x-admin-secret (required)
- **Query params**
 - startTime (ISO timestamp string, required)
 - endTime (ISO timestamp string, required)
- **Success**
 - **200** {"report": [...]}
 - Returned columns:
 - ts, date, time, longitude, latitude, amount, created_at, fraud_flag, fraud_reason, fraud_checked_at, txn_id
- **Errors**

- **400** {"error":"Missing startTime or endTime (ISO string expected)"}
- **400** {"error":"Invalid startTime or endTime"}
- **400** {"error":"<db error message>"}

Example:

```
curl "<BASE_URL>/dailyreport?startTime=2025-12-01T00:00:00Z&endTime=2025-12-02T00:00:00Z" \
-H "x-admin-secret: $EDGE_ADMIN_SECRET"
```

GET /transactions

List up to 100 transactions for a user (most recent first).

- **Method:** GET
- **Path:** /transactions
- **Headers**
 - x-admin-secret (required)
 - user_id (required; this is the user whose transactions you are requesting)
- **Success**
 - **200** {"transactions":[...]}
- **Errors**
 - **403** {"error":"Forbidden"} (missing user_id)
 - **400** {"error":"<db error message>"}

Example:

```
curl "<BASE_URL>/transactions" \
-H "x-admin-secret: $EDGE_ADMIN_SECRET" \
-H "user_id: <uuid>"
```

POST /transactions

Create a transaction row.

- **Method:** POST
- **Path:** /transactions
- **Headers**
 - x-admin-secret (required)
 - Content-Type: application/json
- **Body**
 - userId (string, required)
 - ccNumber (string/number, required)
 - longitude (number, required)
 - latitude (number, required)
 - amount (number, required)
 - date (string, optional)
 - time (string, optional)
 - fraud_flag (boolean, optional)
 - fraud_reason (string, optional)
- **Success**
 - **201** {"transaction": <inserted-row>}
- **Errors**
 - **400** {"error": "Invalid or empty JSON"}
 - **400** {"error": "Missing required fields: userId, ccNumber, longitude, latitude, amount"}
 - **400** {"error": "<db error message>"}

Example:

```
curl -X POST "<BASE_URL>/transactions" \
-H "x-admin-secret: $EDGE_ADMIN_SECRET" \
-H "Content-Type: application/json" \
-d '{"userId":"<uuid>","ccNumber":"4111111111111111","longitude":-73.9857,"latitude":40.7484,"amount":42.50}'
```

PUT /transactions

Update fraud status for a transaction (by txn_id) and stamp fraud_checked_at.

- **Method:** PUT

- **Path:** /transactions
- **Headers**
 - x-admin-secret (required)
 - Content-Type: application/json
- **Body**
 - transactionId (string, required; maps to txn_id)
 - fraud_flag (boolean, required)
 - fraud_reason (string, optional)
- **Success**
 - **200** {"transaction": <updated-row>}
- **Errors**
 - **400** {"error": "Invalid or empty JSON"}
 - **400** {"error": "Missing required fields: transactionId (uuid), fraud_flag (boolean)"}
 - **400** {"error": "<db error message>"}

Example:

```
curl -X PUT "<BASE_URL>/transactions" \
-H "x-admin-secret: $EDGE_ADMIN_SECRET" \
-H "Content-Type: application/json" \
-d '{"transactionId": "<txn_uuid>", "fraud_flag": true, "fraud_reason": "High-risk pattern"}'
```

GET /user

Fetch a user record plus their credit cards.

- **Method:** GET
- **Path:** /user
- **Headers**
 - x-admin-secret (required)
 - user_id (required)
- **Success**
 - **200**
 - {"user": {"id", "name", "isAdmin", "creditCards": [...]}}
- **Errors**

- **403** {"error": "Forbidden"} (missing user_id)
- **404** {"error": "User not found"}
- **400** {"error": "<db error message>"}

Example:

```
curl "<BASE_URL>/user" \
-H "x-admin-secret: $EDGE_ADMIN_SECRET" \
-H "user_id: <uuid>"
```

POST /creditcard

Create a credit card row.

- **Method:** POST
- **Path:** /creditcard
- **Headers**
 - x-admin-secret (required)
 - Content-Type: application/json
- **Body**
 - userId (string, required)
 - ccNumber (string/number, required)
 - exp (string, required)
 - sec (string/number, required)
 - iss (string, required)
- **Success**
 - **201** {"creditCard":{"ccNumber","exp","iss","created_at"}}
- **Errors**
 - **400** {"error": "Invalid or empty JSON"}
 - **400** {"error": "Missing required fields: userId, ccNumber, exp, sec, iss"}
 - **400** {"error": "<db error message>"}

Example:

```
curl -X POST "<BASE_URL>/creditcard" \
-H "x-admin-secret: $EDGE_ADMIN_SECRET" \
-H "Content-Type: application/json" \
```

-d

```
'{"userId":"<uuid>","ccNumber":"4111111111111111","exp":"12/27","sec":"123","iss":"VISA"}'
```